

01 de Octubre del 2026

RED TEAM

Evaluación de Seguridad: My File Server

Luis Felipe Jaramillo Barajas

PAGE 1

Contexto del Engagement

Se realizó una evaluación de seguridad ofensiva (pentesting) sobre la máquina My File Server: 1, la cual es entorno corporativo de almacenamiento de archivos

El objetivo fue identificar, explotar y documentar las vulnerabilidades presentes, evaluando el nivel de exposición real del sistema ante un atacante.

- Tipo de prueba: Caja negra, sin credenciales ni documentación previa del sistema.
- Entorno: laboratorio controlado y aislado con red solo-anfitrión.
- Máquina atacante: Kali Linux.

Metodología aplicada



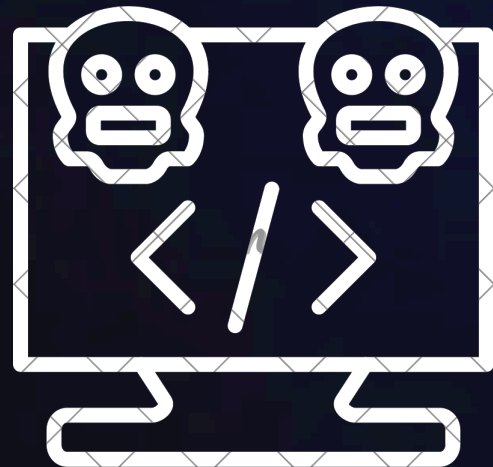
● RECONOCIMIENTO:
DESCUBRIMIENTO DE HOST
ACTIVO EN LA RED.



● ENUMERACIÓN: IDENTIFICACIÓN DE PUERTOS,
SERVICIOS, VERSIONES Y RECURSOS
COMPARTIDOS.



● ANÁLISIS DE VULNERABILIDADES:
CORRELACIÓN DE VERSIONES DE
SOFTWARE Y CONFIGURACIONES
CONTRA VULNERABILIDADES
CONOCIDAS.



● EXPLOTACIÓN: OBTENCIÓN DE
ACCESO INICIAL AL SISTEMA.

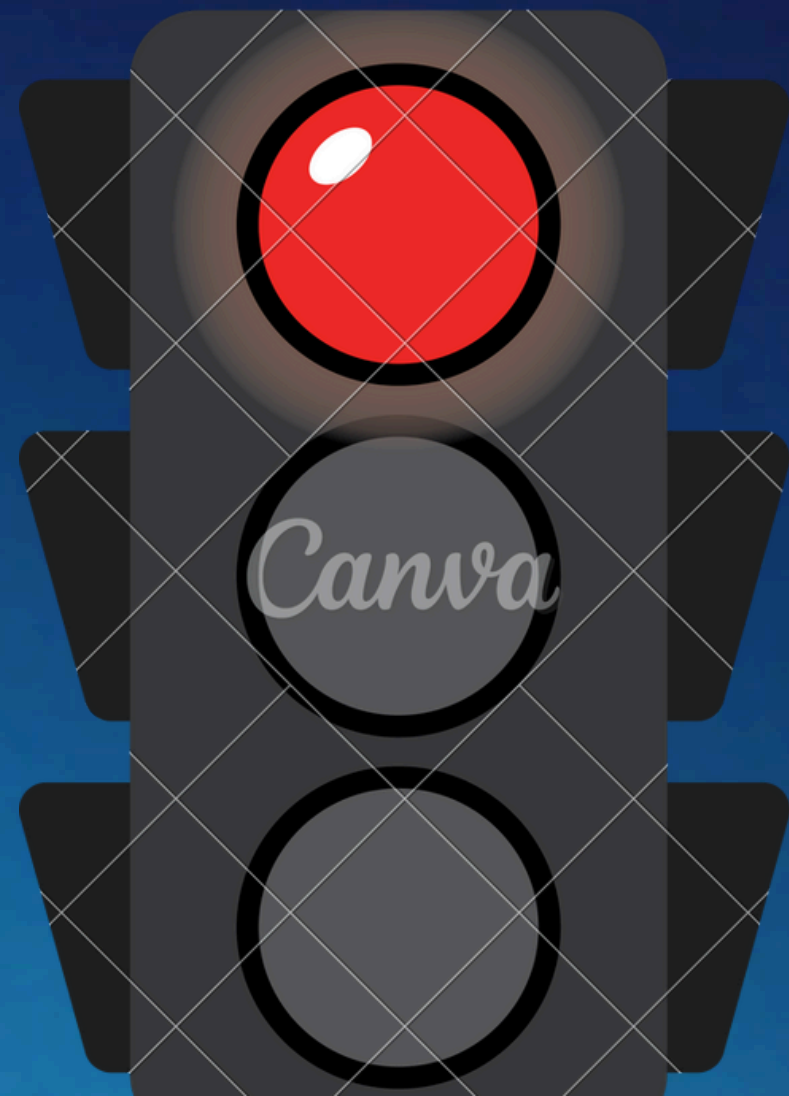


● ESCALADA DE PRIVILEGIOS: ELEVACIÓN DE
ACCESO DE USUARIO ESTÁNDAR A ROOT.



● DOCUMENTACIÓN: REGISTRO DE
EVIDENCIA TÉCNICA EN CADA FASE.

Nivel general del riesgo



**Compromiso total del sistema en
menos de 2 horas**

Hallazgos críticos

Hallazgo 1

Credenciales en texto plano expuestas en el servidor web



Impacto:

Compromiso directo de una cuenta válida del sistema

Hallazgo 2

Kernel vulnerable a DirtyCOW



Impacto:

Compromiso total del sistema: confidencialidad, integridad y disponibilidad

Escenario de impacto empresarial

"My File Server" representa un servidor de archivos corporativo típico. Si este fuera el servidor real de la empresa, un atacante externo habría podido:



Robo de información

Acceso de lectura a todos los archivos almacenados en el servidor (contratos, nóminas, documentos internos).



Secuestro de datos

Con acceso root, el atacante pudo cifrar o eliminar archivos, dejando a la empresa sin acceso a su propia información.



Interrupción del servicio

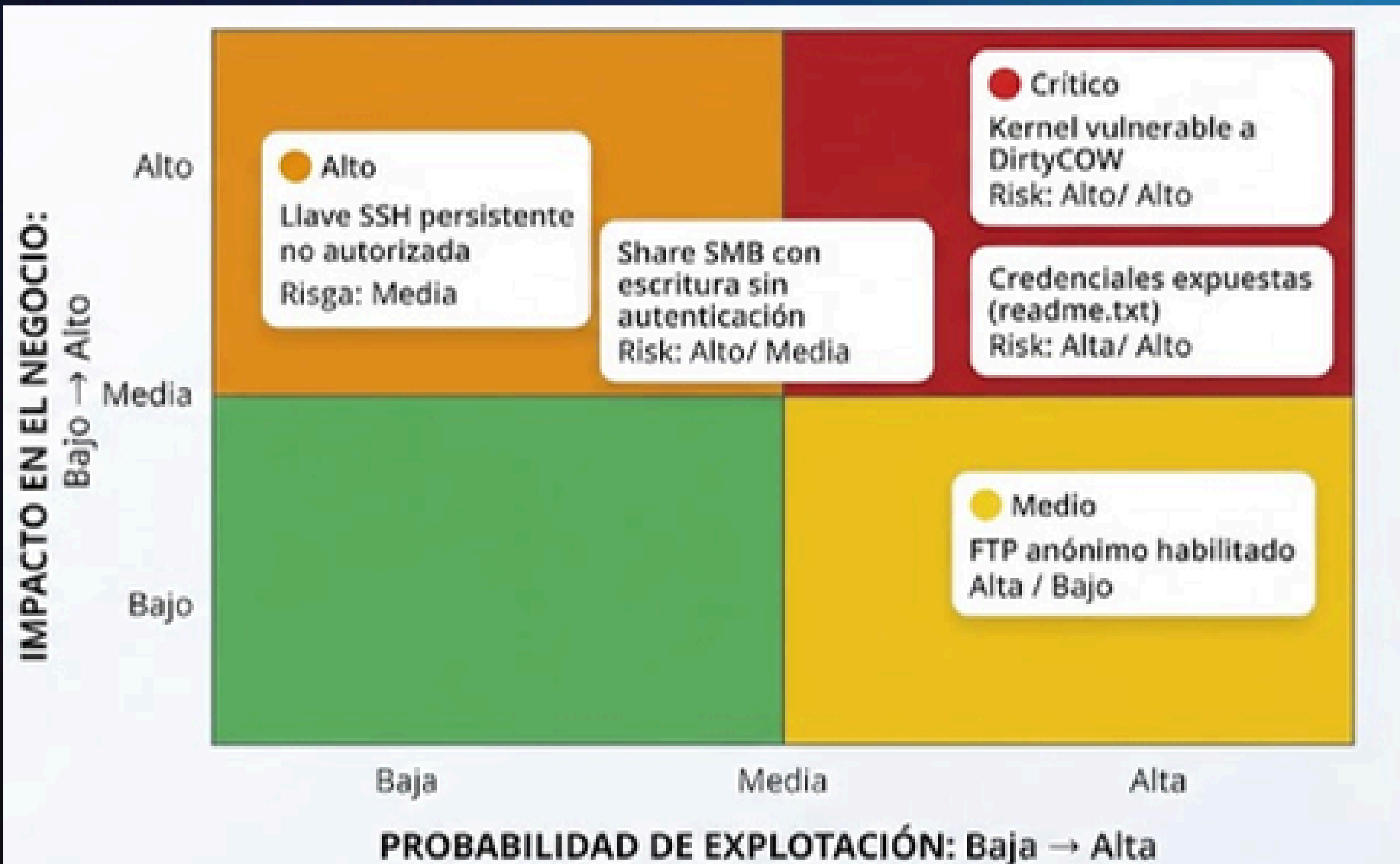
Capacidad de detener el servicio de archivos, afectando a todos los empleados que dependen de él para trabajar.



Persistencia silenciosa

El acceso por llave SSH permite al atacante regresar cuando quiera, sin que nadie lo note, incluso después de cambiar la contraseña original.

Matriz de Riesgo



*(Probabilidad
× Impacto)*

Recomendaciones Estratégicas

¿Qué debe hacer la organización?



Actualizar y parchar sistemas:

Mantener los servidores al día evita que vulnerabilidades conocidas desde 2016 (como esta) sigan siendo explotables hoy.



Revisar permisos de accesos

compartidos: Ningún recurso de archivos debe permitir escritura sin autenticación verificada.



Auditar contenido publicado:

Ningún archivo con credenciales o datos sensibles debe quedar accesible públicamente, ni por descuido.



Establecer un programa continuo de pruebas de seguridad: Este tipo de hallazgos se detectan antes de un incidente real solo si se buscan de forma proactiva y periódica.

Roadmap de Remediación



Inmediato
(0–7 días)



Corto plazo
(2–4 semanas)



Mediano plazo
(1–3 meses)

⊗ Eliminar el archivo con credenciales expuestas del servidor web

🔒 Deshabilitar el login anónimo de FTP

🔒 Revocar la llave SSH no autorizada

- Actualizar el kernel del servidor a una versión parchada

- Reconfigurar permisos del recurso compartido SMB

🔒 Forzar autenticación en todos los servicios de archivos

- Implementar monitoreo/alertas ante cambios en archivos de configuración críticos (como `authorized_keys`)

- Establecer un calendario recurrente de pentesting interno o externo

- Capacitar al equipo técnico en buenas prácticas de hardening de servidores

Conclusión

Se identificaron 5 hallazgos, 2 de ellos críticos. La combinación de fallas de configuración simples permitió el compromiso total del sistema en menos de una hora.

```
file included from 40616.c:28:0:
usr/include/unistd.h:334:16: note: expected '__off_t' but argument is of type 'voi
l *'
extern __off_t lseek (int __fd, __off_t __offset, int __whence) __THROW;

[smbuser@fileserver ~]$ ./exploit
DirtyCow root privilege escalation
Backing up /usr/bin/passwd.. to /tmp/bak
Size of binary: 27832
Patching, this may take a while..
thread stopped
thread stopped
/usr/bin/passwd is overwritten
Popping root shell.
Don't forget to restore /tmp/bak
root@fileserver smbuser)# cd /root
root@fileserver root)# ls
proof.txt
root@fileserver root)# cat proof.txt
Best of Luck
f52e0163b03cbf7c6dd146351594a43
root@fileserver root)#
```



La seguridad no depende de prevenir un solo error grave, sino de no acumular varios errores pequeños.



Se recomienda NO desplegar este servicio en producción hasta remediar los hallazgos críticos (H03 y H05) documentados en este informe.